Protect Account Data

Requirement 3: Protect Stored Account Data

Sections

3.1 Processes and mechanisms for protecting stored account data are defined and understood.

3.2 Storage of account data is kept to a minimum.

3.3 Sensitive authentication data (SAD) is not stored after authorization.

3.4 Access to displays of full PAN and ability to copy PAN are restricted.

3.5 Primary account number (PAN) is secured wherever it is stored.

3.6 Cryptographic keys used to protect stored account data are secured.

3.7 Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented.

Overview

Protection methods such as encryption, truncation, masking, and hashing are critical components of account data protection. If an intruder circumvents other security controls and gains access to encrypted account data, the data is unreadable without the proper cryptographic keys and is unusable to that intruder. Other effective methods of protecting stored data should also be considered as potential risk-mitigation opportunities. For example, methods for minimizing risk include not storing account data unless necessary, truncating cardholder data if full PAN is not needed, and not sending unprotected PANs using end-user messaging technologies such as e-mail and instant messaging.

If account data is present in non-persistent memory (for example, RAM, volatile memory), encryption of PAN is not required. However, proper controls must be in place to ensure that memory maintains a non-persistent state. Data should be removed from volatile memory once the business purpose (for example, the associated transaction) is complete. In the case that data storage becomes persistent, all applicable PCI DSS Requirements will apply including encryption of stored data.

Requirement 3 applies to protection of stored account data unless specifically called out in an individual requirement.

Refer to *Appendix G* for definitions of “strong cryptography” and other PCI DSS terms.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.1 Processes and mechanisms for protecting stored account data are defined and understood.		
Defined Approach Requirements **3.1.1** All security policies and operational procedures that are identified in Requirement 3 are: • Documented. • Kept up to date. • In use. • Known to all affected parties. **Customized Approach Objective** Expectations, controls, and oversight for meeting activities within Requirement 3 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.	**Defined Approach Testing Procedures** **3.1.1** Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 3 are managed in accordance with all elements specified in this requirement.	**Purpose** Requirement 3.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 3. While it is important to define the specific policies or procedures called out in Requirement 3, it is equally important to ensure they are properly documented, maintained, and disseminated. **Good Practice** It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. **Definitions** Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities, and critical activities may not occur. **Good Practice** Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. **Examples** A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
3.1.2 Roles and responsibilities for performing activities in Requirement 3 are documented, assigned, and understood.	**3.1.2.a** Examine documentation to verify that descriptions of roles and responsibilities performing activities in Requirement 3 are documented and assigned.	
	3.1.2.b Interview personnel with responsibility for performing activities in Requirement 3 to verify that roles and responsibilities are assigned as documented and are understood.	
Customized Approach Objective		
Day-to-day responsibilities for performing all the activities in Requirement 3 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.2 Storage of account data is kept to a minimum.		
Defined Approach Requirements **3.2.1** Account data storage is kept to a minimum through implementation of data retention and disposal policies, procedures, and processes that include at least the following: • Coverage for all locations of stored account data. • Coverage for any sensitive authentication data (SAD) stored prior to completion of authorization. *This bullet is a best practice until its effective date; refer to Applicability Notes below for details.* • Limiting data storage amount and retention time to that which is required for legal or regulatory, and/or business requirements. • Specific retention requirements for stored account data that defines length of retention period and includes a documented business justification. • Processes for secure deletion or rendering account data unrecoverable when no longer needed per the retention policy. • A process for verifying, at least once every three months, that stored account data exceeding the defined retention period has been securely deleted or rendered unrecoverable. **Customized Approach Objective** Account data is retained only where necessary and for the least amount of time needed and is securely deleted or rendered unrecoverable when no longer needed.	**Defined Approach Testing Procedures** **3.2.1.a** Examine the data retention and disposal policies, procedures, and processes and interview personnel to verify processes are defined to include all elements specified in this requirement. **3.2.1.b** Examine files and system records on system components where account data is stored to verify that the data storage amount and retention time does not exceed the requirements defined in the data retention policy. **3.2.1.c** Observe the mechanisms used to render account data unrecoverable to verify data cannot be recovered.	**Purpose** A formal data retention policy identifies what data needs to be retained, for how long, and where that data resides so it can be securely destroyed or deleted as soon as it is no longer needed. The only account data that may be stored after authorization is the primary account number or PAN (rendered unreadable), expiration date, cardholder name, and service code. The storage of SAD data prior to the completion of the authorization process is also included in the data retention and disposal policy so that storage of this sensitive data is kept to minimum, and only retained for the defined amount of time. **Good Practice** When identifying locations of stored account data, consider all processes and personnel with access to the data, as data could have been moved and stored in different locations than originally defined. Storage locations that are often overlooked include backup and archive systems, removable data storage devices, paper-based media, and audio recordings. To define appropriate retention requirements, an entity first needs to understand its own business needs as well as any legal or regulatory obligations that apply to its industry or to the type of data being retained. Implementing an automated process to ensure data is automatically and securely deleted upon its defined retention limit can help ensure that account data is not retained beyond what is necessary for business, legal, or regulatory purposes. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes Where account data is stored by a TPSP (for example, in a cloud environment), entities are responsible for working with their service providers to understand how the TPSP meets this requirement for the entity. Considerations include ensuring that all geographic instances of a data element are securely deleted. *The bullet above (for coverage of SAD stored prior to completion of authorization) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.2.1 and must be fully considered during a PCI DSS assessment.*		Methods of eliminating data when it exceeds the retention period include secure deletion to complete removal of the data or rendering it unrecoverable and unable to be reconstructed. Identifying and securely eliminating stored data that has exceeded its specified retention period prevents unnecessary retention of data that is no longer needed. This process may be automated, manual, or a combination of both. The deletion function in most operating systems is not "secure deletion" as it allows deleted data to be recovered, so instead, a dedicated secure deletion function or application must be used to make data unrecoverable. *Remember, if you don't need it, don't store it!* **Examples** An automated, programmatic procedure could be run to locate and remove data, or a manual review of data storage areas could be performed. Whichever method is used, it is a good idea to monitor the process to ensure it is completed successfully, and that the results are recorded and validated as being complete. Implementing secure deletion methods ensures that the data cannot be retrieved when it is no longer needed. **Further Information** See *NIST SP 800-88 Rev. 1, Guidelines for Media Sanitization*.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.3 Sensitive authentication data (SAD) is not stored after authorization.		
Defined Approach Requirements **3.3.1** SAD is not stored after authorization, even if encrypted. All sensitive authentication data received is rendered unrecoverable upon completion of the authorization process. **Customized Approach Objective** This requirement is not eligible for the customized approach. **Applicability Notes** Issuers and companies that support issuing services, where there is a legitimate and documented business need to store SAD, are not required to meet this requirement. A legitimate business need is one that is necessary for the performance of the function being provided by or for the issuer. Refer to Requirement 3.3.3 for additional requirements specifically for these entities. Sensitive authentication data includes the data cited in Requirements 3.3.1.1 through 3.3.1.3.	**Defined Approach Testing Procedures** **3.3.1.a** If SAD is received, examine documented policies, procedures, and system configurations to verify the data is not stored after authorization. **3.3.1.b** If SAD is received, examine the documented procedures and observe the secure data deletion processes to verify the data is rendered unrecoverable upon completion of the authorization process.	**Purpose** SAD is very valuable to malicious individuals as it allows them to generate counterfeit payment cards and create fraudulent transactions. Therefore, the storage of SAD upon completion of the authorization process is prohibited. **Good Practice** It may be acceptable for an entity to store SAD in non-persistent memory for a short time after authorization is complete, if following conditions are met: • There is a legitimate business need to access SAD in memory after authorization is complete. • SAD is only ever stored in non-persistent memory (for example, RAM, volatile memory). • Controls are in place to ensure that memory maintains a non-persistent state. • SAD is removed as soon as the business purpose is complete. It is not permissible to store SAD in persistent memory. **Definitions** The authorization process completes when a merchant receives a transaction response (for example, an approval or decline). Refer to *Appendix G* for the definition of “authorization.”

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.3.1.1** The full contents of any track are not stored upon completion of the authorization process. **Customized Approach Objective** This requirement is not eligible for the customized approach. **Applicability Notes** In the normal course of business, the following data elements from the track may need to be retained: • Cardholder name. • Primary account number (PAN). • Expiration date. • Service code. To minimize risk, store securely only these data elements as needed for business.	**Defined Approach Testing Procedures** **3.3.1.1** Examine data sources to verify that the full contents of any track are not stored upon completion of the authorization process.	**Purpose** If full contents of any track (from the magnetic stripe on the back of a card if present, equivalent data contained on a chip, or elsewhere) is stored, malicious individuals who obtain that data can use it to reproduce payment cards and complete fraudulent transactions. **Definitions** Full track data is alternatively called full track, track, track 1, track 2, and magnetic-stripe data. Each track contains a number of data elements, and this requirement specifies only those that may be retained post-authorization. **Examples** Data sources to review to ensure that the full contents of any track are not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.3.1.2** The card verification code is not stored upon completion of the authorization process. **Customized Approach Objective** This requirement is not eligible for the customized approach. **Applicability Notes** The card verification code is the three- or four-digit number printed on the front or back of a payment card used to verify card-not-present transactions.	**Defined Approach Testing Procedures** **3.3.1.2** Examine data sources, to verify that the card verification code is not stored upon completion of the authorization process.	**Purpose** If card verification code data is stolen, malicious individuals can execute fraudulent Internet and mail-order/telephone-order (MO/TO) transactions. Not storing this data reduces the probability of it being compromised. **Examples** If card verification codes are stored on paper media prior to completion of authorization, a method of erasing or covering the codes should prevent them from being read after authorization is complete. Example methods of rendering the codes unreadable include removing the code with scissors and applying a suitably opaque and un-removable marker over the code. Data sources to review to ensure that the card verification code is not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.3.1.3** The personal identification number (PIN) and the PIN block are not stored upon completion of the authorization process. **Customized Approach Objective** This requirement is not eligible for the customized approach. **Applicability Notes** PIN blocks are encrypted during the natural course of transaction processes, but even if an entity encrypts the PIN block again, it is still not allowed to be stored after the completion of the authorization process.	**Defined Approach Testing Procedures** **3.3.1.3** Examine data sources, to verify that PINs and PIN blocks are not stored upon completion of the authorization process.	**Purpose** PIN and PIN blocks should be known only to the card owner or entity that issued the card. If this data is stolen, malicious individuals can execute fraudulent PIN-based transactions (for example, in-store purchases and ATM withdrawals). Not storing this data reduces the probability of it being compromised. **Examples** Data sources to review to ensure that PIN and PIN blocks are not retained upon completion of the authorization process include, but are not limited to: • Incoming transaction data. • All logs (for example, transaction, history, debugging, error). • History files. • Trace files. • Database schemas. • Contents of databases, and on-premise and cloud data stores. • Any existing memory/crash dump files.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.3.2** SAD that is stored electronically prior to completion of authorization is encrypted using strong cryptography. **Customized Approach Objective** This requirement is not eligible for the customized approach. *(continued on next page)*	**Defined Approach Testing Procedures** **3.3.2** Examine data stores, system configurations, and/or vendor documentation to verify that all SAD that is stored electronically prior to completion of authorization is encrypted using strong cryptography.	**Purpose** SAD can be used by malicious individuals to increase the probability of successfully generating counterfeit payment cards and creating fraudulent transactions. **Good Practice** Entities should consider encrypting SAD with a different cryptographic key than is used to encrypt PAN. Note that this does not mean that PAN present in SAD (as part of track data) would need to be separately encrypted.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes Whether SAD is permitted to be stored prior to authorization is determined by the organizations that manage compliance programs (for example, payment brands and acquirers). Contact these organizations for any additional criteria. This requirement applies to all storage of SAD, even if no PAN is present in the environment. Refer to Requirement 3.2.1 for an additional requirement that applies if SAD is stored prior to completion of authorization. Issuers and companies that support issuing services, where there is a legitimate and documented business need to store SAD, are not required to meet this requirement. A legitimate business need is one that is necessary for the performance of the function being provided by or for the issuer. Refer to Requirement 3.3.3 for requirements specifically for these entities. This requirement does not replace how PIN blocks are required to be managed, nor does it mean that a properly encrypted PIN block needs to be encrypted again. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*		**Definitions** The authorization process is completed when a merchant receives a transaction response (for example, an approval or decline) . Refer to *Appendix G* for the definition of “authorization.”

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** SAD can be used by malicious individuals to increase the probability of successfully generating counterfeit payment cards and creating fraudulent transactions. **Good Practice** Entities should consider encrypting SAD with a different cryptographic key than is used to encrypt PAN. Note that this does not mean that PAN present in SAD (as part of track data) would need to be separately encrypted.
3.3.3 ***Additional requirement for issuers and companies that support issuing services and store sensitive authentication data:*** Any storage of sensitive authentication data is: • Limited to that which is needed for a legitimate issuing business need and is secured. • Encrypted using strong cryptography. *This bullet is a best practice until its effective date; refer to Applicability Notes below for details.*	**3.3.3.a** ***Additional testing procedure for issuers and companies that support issuing services and store sensitive authentication data:*** Examine documented policies and interview personnel to verify there is a documented business justification for the storage of sensitive authentication data.	
Customized Approach Objective	**3.3.3.b** ***Additional testing procedure for issuers and companies that support issuing services and store sensitive authentication data:*** Examine data stores and system configurations to verify that the sensitive authentication data is stored securely.	
Sensitive authentication data is retained only as required to support issuing functions and is secured from unauthorized access. *(continued on next page)*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only to issuers and companies that support issuing services and store sensitive authentication data. Entities that issue payment cards or that perform or support issuing services will often create and control sensitive authentication data as part of the issuing function. It is allowable for companies that perform, facilitate, or support issuing services to store sensitive authentication data ONLY IF they have a legitimate business need to store such data. A legitimate issuing business need is one that is necessary for the performance of the function being provided by or for the issuer. *The bullet above (for encrypting stored SAD with strong cryptography) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.3.3 and must be fully considered during a PCI DSS assessment.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.4 Access to displays of full PAN and ability to copy PAN are restricted.		
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** The display of full PAN on computer screens, payment card receipts, paper reports, etc. can result in this data being obtained by unauthorized individuals and used fraudulently. Ensuring that the full PAN is displayed only for those with a legitimate business need minimizes the risk of unauthorized persons gaining access to PAN data. **Good Practice** Applying access controls according to defined roles is one way to limit access to viewing full PAN to only those individuals with a defined business need. The masking approach should always display only the number of digits needed to perform a specific business function. For example, if only the last four digits are needed to perform a business function, PAN should be masked to only show the last four digits. As another example, if a function needs to view the bank identification number (BIN) for routing purposes, unmask only the BIN digits for that function. *(continued on next page)*
3.4.1 PAN is masked when displayed (the BIN and last four digits **are the maximum number** of digits to be displayed), such that only personnel with a legitimate business need can see **more than** the BIN and last four digits of the PAN. *(continued on next page)*	**3.4.1.a** Examine documented policies and procedures for masking the display of PANs to verify: • A list of roles that need access to more than the BIN and last four digits of the PAN (includes full PAN) is documented, together with a legitimate business need for each role to have such access. • PAN is masked when displayed such that only personnel with a legitimate business need can see more than the BIN and last four digits of the PAN. • All roles not specifically authorized to see the full PAN must only see masked PANs.	
	3.4.1.b Examine system configurations to verify that full PAN is only displayed for roles with a documented business need, and that PAN is masked for all other requests.	
	3.4.1.c Examine displays of PAN (for example, on screen, on paper receipts) to verify that PANs are masked when displayed, and that only those with a legitimate business need are able to see more than the BIN and/or last four digits of the PAN.	

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Customized Approach Objective PAN displays are restricted to the minimum number of digits necessary to meet a defined business need. **Applicability Notes** This requirement does not supersede stricter requirements in place for displays of cardholder data—for example, legal or payment brand requirements for point-of-sale (POS) receipts. This requirement relates to protection of PAN where it is displayed on screens, paper receipts, printouts, etc., and is not to be confused with Requirement 3.5.1 for protection of PAN when stored, processed, or transmitted.		**Definitions** Masking is not synonymous with truncation and these terms cannot be used interchangeably. Masking refers to the concealment of certain digits during display or printing, even when the entire PAN is stored on a system. This is different from truncation, in which the truncated digits are removed and cannot be retrieved within the system. Masked PAN could be “unmasked”, but there is no "un-truncation" without recreating the PAN from another source. Refer to *Appendix G* for definitions of “masking” and “truncation.” **Further Information** For more information about masking and truncation, see PCI SSC’s FAQs on these topics.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.4.2** When using remote-access technologies, technical controls prevent copy and/or relocation of PAN for all personnel, except for those with documented, explicit authorization and a legitimate, defined business need. **Customized Approach Objective** PAN cannot be copied or relocated by unauthorized personnel using remote-access technologies. **Applicability Notes** Storing or relocating PAN onto local hard drives, removable electronic media, and other storage devices brings these devices into scope for PCI DSS. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*	**Defined Approach Testing Procedures** **3.4.2.a** Examine documented policies and procedures and documented evidence for technical controls that prevent copy and/or relocation of PAN when using remote-access technologies onto local hard drives or removable electronic media to verify the following: • Technical controls prevent all personnel not specifically authorized from copying and/or relocating PAN. • A list of personnel with permission to copy and/or relocate PAN is maintained, together with the documented, explicit authorization and legitimate, defined business need. **3.4.2.b** Examine configurations for remote-access technologies to verify that technical controls to prevent copy and/or relocation of PAN for all personnel, unless explicitly authorized. **3.4.2.c** Observe processes and interview personnel to verify that only personnel with documented, explicit authorization and a legitimate, defined business need have permission to copy and/or relocate PAN when using remote-access technologies.	**Purpose** Relocation of PAN to unauthorized storage devices is a common way for this data to be obtained and used fraudulently. Methods to ensure that only those with explicit authorization and a legitimate business reason can copy or relocate PAN minimizes the risk of unauthorized persons gaining access to PAN. **Good Practice** Copying and relocation of PAN should only be done to storage devices that are permissible and authorized for that individual. **Definitions** A virtual desktop is an example of a remote-access technology. Such remote access technologies often include tools to disable copy and/or relocation functionality. Storage devices include, but are not limited to, local hard drives, virtual drives, removable electronic media, network drives, and cloud storage. **Further Information** Vendor documentation for the remote-access technology in use will provide information about the system settings needed to implement this requirement.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.5 Primary account number (PAN) is secured wherever it is stored.		
Defined Approach Requirements **3.5.1** PAN is rendered unreadable anywhere it is stored by using any of the following approaches: • One-way hashes based on strong cryptography of the entire PAN. • Truncation (hashing cannot be used to replace the truncated segment of PAN). – If hashed and truncated versions of the same PAN, or different truncation formats of the same PAN, are present in an environment, additional controls are in place such that the different versions cannot be correlated to reconstruct the original PAN. • Index tokens. • Strong cryptography with associated key-management processes and procedures. **Customized Approach Objective** Cleartext PAN cannot be read from storage media. **Applicability Notes** This requirement applies to PANs stored in primary storage (databases, or flat files such as text files spreadsheets) as well as non-primary storage (backup, audit logs, exception, or troubleshooting logs). This requirement does not preclude the use of temporary files containing cleartext PAN while encrypting and decrypting PAN.	**Defined Approach Testing Procedures** **3.5.1.a** Examine documentation about the system used to render PAN unreadable, including the vendor, type of system/process, and the encryption algorithms (if applicable) to verify that the PAN is rendered unreadable using any of the methods specified in this requirement. **3.5.1.b** Examine data repositories and audit logs, including payment application logs, to verify the PAN is rendered unreadable using any of the methods specified in this requirement. **3.5.1.c** If hashed and truncated versions of the same PAN are present in the environment, examine implemented controls to verify that the hashed and truncated versions cannot be correlated to reconstruct the original PAN.	**Purpose** Rendering stored PAN unreadable is a defense in depth control designed to protect the data if an unauthorized individual gains access to stored data by taking advantage of a vulnerability or misconfiguration of an entity's primary access control. **Good Practice** It is a relatively trivial effort for a malicious individual to reconstruct original PAN data if they have access to both the truncated and hashed versions of a PAN. Controls that prevent the correlation of this data will help ensure that the original PAN remains unreadable. Implementing keyed cryptographic hashes with associated key management processes and procedures in accordance with Requirement 3.5.1.1 is a valid additional control to prevent correlation. **Further Information** For information about truncation formats and truncation in general, see PCI SSC's FAQs on the topic. Sources for information about index tokens include: • PCI SSC's Tokenization Product Security Guidelines (*https://www.pcisecuritystandards.org/documents/Tokenization_Product_Security_Guidelines.pdf*) • *ANSI X9.119-2-2017: Retail Financial Services - Requirements For Protection Of Sensitive Payment Card Data - Part 2: Implementing Post-Authorization Tokenization Systems*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.5.1.1** Hashes used to render PAN unreadable (per the first bullet of Requirement 3.5.1) are keyed cryptographic hashes of the entire PAN, with associated key-management processes and procedures in accordance with Requirements 3.6 and 3.7.	**Defined Approach Testing Procedures** **3.5.1.1.a** Examine documentation about the hashing method used to render PAN unreadable, including the vendor, type of system/process, and the encryption algorithms (as applicable) to verify that the hashing method results in keyed cryptographic hashes of the entire PAN, with associated key management processes and procedures.	**Purpose** Rendering stored PAN unreadable is a defense in depth control designed to protect the data if an unauthorized individual gains access to stored data by taking advantage of a vulnerability or misconfiguration of an entity's primary access control. A hashing function that incorporates a randomly generated secret key provides brute force attack resistance and secret authentication integrity.
Customized Approach Objective Cleartext PAN cannot be determined from hashes of the PAN.	**3.5.1.1.b** Examine documentation about the key management procedures and processes associated with the keyed cryptographic hashes to verify keys are managed in accordance with Requirements 3.6 and 3.7.	**Definitions** Refer to *Appendix G* for the definition of "keyed cryptographic hash" and for information about appropriate keyed cryptographic hashing algorithms and additional resources.
	3.5.1.1.c Examine data repositories to verify the PAN is rendered unreadable.	**Examples** Systems which only have access to one hash value at a time and which store no other account data on the same system as the hash, are not required to meet key-management processes and procedures (Requirements 3.6 and 3.7). Examples of such systems include transaction-originating devices that generate a hash of the PAN for use in a backend system, such as pay-at-gate transit turnstiles. However, in such an implementation, the backend system will have access to more than one hash value at a time, and therefore is required to meet key-management processes and procedures at Requirements 3.6 and 3.7.
Applicability Notes All Applicability Notes for Requirement 3.5.1 also apply to this requirement. *(continued on next page)*	**3.5.1.1.d** Examine audit logs, including payment application logs, to verify the PAN is rendered unreadable.	

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
(continued) Key-management processes and procedures (Requirements 3.6 and 3.7) do not apply to system components used to generate individual keyed hashes of a PAN for comparison to another system if: • The system components only have access to one hash value at a time (hash values are not stored on the system) **AND** • There is no other account data stored on the same system as the hashes. *This requirement is considered a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment. This requirement will replace the bullet in Requirement 3.5.1 for one-way hashes once its effective date is reached.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.5.1.2** If disk-level or partition-level encryption (rather than file-, column-, or field-level database encryption) is used to render PAN unreadable, it is implemented only as follows: • On removable electronic media **OR** • If used for non-removable electronic media, PAN is also rendered unreadable via another mechanism that meets Requirement 3.5.1. **Customized Approach Objective** Encrypted PAN is only decrypted when there is a legitimate business need to access that PAN. *(continued on next page)*	**Defined Approach Testing Procedures** **3.5.1.2.a** Examine encryption processes to verify that, if disk-level or partition-level encryption is used to render PAN unreadable, it is implemented only as follows: • On removable electronic media, **OR** • If used for non-removable electronic media, examine encryption processes used to verify that PAN is also rendered unreadable via another method that meets Requirement 3.5.1. **3.5.1.2.b** Examine configurations and/or vendor documentation and observe encryption processes to verify the system is configured according to vendor documentation the result is that the disk or the partition is rendered unreadable.	**Purpose** Disk-level and partition-level encryption typically encrypts the entire disk or partition using the same key, with all data automatically decrypted when the system runs or when an authorized user requests it. For this reason, disk-level encryption is not appropriate to protect stored PAN on computers, laptops, servers, storage arrays, or any other system that provides transparent decryption upon user authentication. **Further Information** Where available, following vendors' hardening and industry best practice guidelines can assist in securing PAN on these devices.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes		
(continued) This requirement applies to any encryption method that provides clear-text PAN automatically when a system runs, even though an authorized user has not specifically requested that data. While disk or partition encryption may still be present on these types of devices, it cannot be the only mechanism used to protect PAN stored on those systems. Any stored PAN must also be rendered unreadable per Requirement 3.5.1—for example, through truncation or a data-level encryption mechanism. Full disk encryption helps to protect data in the event of physical loss of a disk and therefore its use is appropriate only for removable electronic media storage devices. Media that is part of a data center architecture (for example, hot-swappable drives, bulk tape-backups) is considered non-removable electronic media to which Requirement 3.5.1 applies. Disk or partition encryption implementations must also meet all other PCI DSS encryption and key-management requirements. For issuers and companies that support issuing services: This requirement does not apply to PANs being accessed for real-time transaction processing. However, it does apply to PANs stored for other purposes. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.5.1.3** If disk-level or partition-level encryption is used (rather than file-, column-, or field-level database encryption) to render PAN unreadable, it is managed as follows: • Logical access is managed separately and independently of native operating system authentication and access control mechanisms. • Decryption keys are not associated with user accounts. • Authentication factors (passwords, passphrases, or cryptographic keys) that allow access to unencrypted data are stored securely. **Customized Approach Objective** Disk encryption implementations are configured to require independent authentication and logical access controls for decryption. **Applicability Notes** Disk or partition encryption implementations must also meet all other PCI DSS encryption and key-management requirements.	**Defined Approach Testing Procedures** **3.5.1.3.a** If disk-level or partition-level encryption is used to render PAN unreadable, examine the system configuration and observe the authentication process to verify that logical access is implemented in accordance with all elements specified in this requirement. **3.5.1.3.b** Examine files containing authentication factors (passwords, passphrases, or cryptographic keys) and interview personnel to verify that authentication factors that allow access to unencrypted data are stored securely and are independent from the native operating system's authentication and access control methods.	**Purpose** Disk-level encryption typically encrypts the entire disk or partition using the same key, with all data automatically decrypted when the system runs or when an authorized user requests it. Many disk-encryption solutions intercept operating system read/write operations and perform the appropriate cryptographic transformations without any special action by the user other than supplying a password or passphrase at system start-up or at the beginning of a session. This provides no protection from a malicious individual that has already managed to gain access to a valid user account. **Good Practice** Full disk encryption helps to protect data in the event of physical loss of a disk and therefore its use is best limited only to removable electronic media storage devices.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.6 Cryptographic keys used to protect stored account data are secured.		
Defined Approach Requirements **3.6.1** Procedures are defined and implemented to protect cryptographic keys used to protect stored account data against disclosure and misuse that include: • Access to keys is restricted to the fewest number of custodians necessary. • Key-encrypting keys are at least as strong as the data-encrypting keys they protect. • Key-encrypting keys are stored separately from data-encrypting keys. • Keys are stored securely in the fewest possible locations and forms. **Customized Approach Objective** Processes that protect cryptographic keys used to protect stored account data against disclosure and misuse are defined and implemented. **Applicability Notes** This requirement applies to keys used to protect stored account data and to key-encrypting keys used to protect data-encrypting keys. The requirement to protect keys used to protect stored account data from disclosure and misuse applies to both data-encrypting keys and key-encrypting keys. Because one key-encrypting key may grant access to many data-encrypting keys, the key-encrypting keys require strong protection measures.	**Defined Approach Testing Procedures** **3.6.1** Examine documented key-management policies and procedures to verify that processes to protect cryptographic keys used to protect stored account data against disclosure and misuse are defined to include all elements specified in this requirement.	**Purpose** Cryptographic keys must be strongly protected because those who obtain access will be able to decrypt data. **Good Practice** Having a centralized key management system based on industry standards is recommended for managing cryptographic keys. **Further Information** The entity's key management procedures will benefit through alignment with industry requirements, Sources for information on cryptographic key management life cycles include: • *ISO 11568-1 Banking — Key management (retail) — Part 1*: Principles (specifically Chapter 10 and the referenced Parts 2 & 4) • *NIST SP 800-57 Part 1 Revision 5— Recommendation for Key Management, Part 1: General*.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose**
3.6.1.1 ***Additional requirement for service providers only:*** A documented description of the cryptographic architecture is maintained that includes: • Details of all algorithms, protocols, and keys used for the protection of stored account data, including key strength and expiry date. • Preventing the use of the same cryptographic keys in production and test environments. *This bullet is a best practice until its effective date; refer to Applicability Notes below for details.* • Description of the key usage for each key. • Inventory of any hardware security modules (HSMs), key management systems (KMS), and other secure cryptographic devices (SCDs) used for key management, including type and location of devices, to support meeting Requirement 12.3.4.	**3.6.1.1** ***Additional testing procedure for service provider assessments only:*** Interview responsible personnel and examine documentation to verify that a document exists to describe the cryptographic architecture that includes all elements specified in this requirement.	Maintaining current documentation of the cryptographic architecture enables an entity to understand the algorithms, protocols, and cryptographic keys used to protect stored account data, as well as the devices that generate, use, and protect the keys. This allows an entity to keep pace with evolving threats to its architecture and plan for updates as the assurance level provided by different algorithms and key strengths changes. Maintaining such documentation also allows an entity to detect lost or missing keys or key-management devices and identify unauthorized additions to its cryptographic architecture. The use of the same cryptographic keys in both production and test environments introduces a risk of exposing the key if the test environment is not at the same security level as the production environment. **Good Practice** Having an automated reporting mechanism can assist with maintenance of the cryptographic attributes.
Customized Approach Objective		
Accurate details of the cryptographic architecture are maintained and available. *(continued on next page)*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies only when the entity being assessed is a service provider. In cloud HSM implementations, responsibility for the cryptographic architecture according to this Requirement will be shared between the cloud provider and the cloud customer. *The bullet above (for including, in the cryptographic architecture, that the use of the same cryptographic keys in production and test is prevented) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.6.1.1 and must be fully considered during a PCI DSS assessment.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose**
3.6.1.2 Secret and private keys used to protect stored account data are stored in one (or more) of the following forms at all times: • Encrypted with a key-encrypting key that is at least as strong as the data-encrypting key, and that is stored separately from the data-encrypting key. • Within a secure cryptographic device (SCD), such as a hardware security module (HSM) or PTS-approved point-of-interaction device. • As at least two full-length key components or key shares, in accordance with an industry-accepted method.	**3.6.1.2.a** Examine documented procedures to verify it is defined that cryptographic keys used to encrypt/decrypt stored account data must exist only in one (or more) of the forms specified in this requirement. **3.6.1.2.b** Examine system configurations and key storage locations to verify that cryptographic keys used to encrypt/decrypt stored account data exist in one (or more) of the forms specified in this requirement. **3.6.1.2.c** Wherever key-encrypting keys are used, examine system configurations and key storage locations to verify: • Key-encrypting keys are at least as strong as the data-encrypting keys they protect. • Key-encrypting keys are stored separately from data-encrypting keys.	Storing cryptographic keys securely prevents unauthorized or unnecessary access that could result in the exposure of stored account data. Storing keys separately means they are stored such that if the location of one key is compromised, the second key is not also compromised. **Good Practice** Where data-encrypting keys are stored in an HSM, the HSM interaction channel should be protected to prevent interception of encryption or decryption operations.
Customized Approach Objective		
Secret and private keys are stored in a secure form that prevents unauthorized retrieval or access. *(continued on next page)*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes It is not required that public keys be stored in one of these forms. Cryptographic keys stored as part of a key management system (KMS) that employs SCDs are acceptable. A cryptographic key that is split into two parts does not meet this requirement. Secret or private keys stored as key components or key shares must be generated via one of the following: • Using an approved random number generator and within an SCD, **OR** • According to ISO 19592 or equivalent industry standard for generation of secret key shares.		
Defined Approach Requirements **3.6.1.3** Access to cleartext cryptographic key components is restricted to the fewest number of custodians necessary. **Customized Approach Objective** Access to cleartext cryptographic key components is restricted to necessary personnel.	**Defined Approach Testing Procedures** **3.6.1.3** Examine user access lists to verify that access to cleartext cryptographic key components is restricted to the fewest number of custodians necessary.	**Purpose** Restricting the number of people who have access to cleartext cryptographic key components reduces the risk of stored account data being retrieved or rendered visible by unauthorized parties. **Good Practice** Only personnel with defined key custodian responsibilities (creating, altering, rotating, distributing, or otherwise maintaining encryption keys) should be granted access to key components. Ideally this will be a very small number of people.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose**
3.6.1.4 Cryptographic keys are stored in the fewest possible locations.	**3.6.1.4** Examine key storage locations and observe processes to verify that keys are stored in the fewest possible locations.	Storing any cryptographic keys in the fewest locations helps an organization track and monitor all key locations and minimizes the potential for keys to be exposed to unauthorized parties.
Customized Approach Objective		
Cryptographic keys are retained only where necessary.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.7 Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented.		
Defined Approach Requirements **3.7.1** Key-management policies and procedures are implemented to include generation of strong cryptographic keys used to protect stored account data. **Customized Approach Objective** Strong cryptographic keys are generated.	**Defined Approach Testing Procedures** **3.7.1.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define generation of strong cryptographic keys. **3.7.1.b** Observe the method for generating keys to verify that strong keys are generated.	**Purpose** Use of strong cryptographic keys significantly increases the level of security of encrypted account data. **Further Information** See the sources referenced at Cryptographic Key Generation in *Appendix G*.
Defined Approach Requirements **3.7.2** Key-management policies and procedures are implemented to include secure distribution of cryptographic keys used to protect stored account data. **Customized Approach Objective** Cryptographic keys are secured during distribution.	**Defined Approach Testing Procedures** **3.7.2.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define secure distribution of cryptographic keys. **3.7.2.b** Observe the method for distributing keys to verify that keys are distributed securely.	**Purpose** Secure distribution or conveyance of secret or private cryptographic keys means that keys are distributed only to authorized custodians, as identified in Requirement 3.6.1.2, and are never distributed insecurely.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Storing keys without proper protection could provide access to attackers, resulting in the decryption and exposure of account data. **Good Practice** Data encryption keys can be protected by encrypting them with a key-encrypting key. Keys can be stored in a Hardware Security Module (HSM). Secret or private keys that can decrypt data should never be present in source code.
3.7.3 Key-management policies and procedures are implemented to include secure storage of cryptographic keys used to protect stored account data.	**3.7.3.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define secure storage of cryptographic keys.	
	3.7.3.b Observe the method for storing keys to verify that keys are stored securely.	
Customized Approach Objective		
Cryptographic keys are secured when stored.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.7.4** Key management policies and procedures are implemented for cryptographic key changes for keys that have reached the end of their cryptoperiod, as defined by the associated application vendor or key owner, and based on industry best practices and guidelines, including the following: • A defined cryptoperiod for each key type in use. • A process for key changes at the end of the defined cryptoperiod. **Customized Approach Objective** Cryptographic keys are not used beyond their defined cryptoperiod.	**Defined Approach Testing Procedures** **3.7.4.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data to verify that they define changes to cryptographic keys that have reached the end of their cryptoperiod and include all elements specified in this requirement. **3.7.4.b** Interview personnel, examine documentation, and observe key storage locations to verify that keys are changed at the end of the defined cryptoperiod(s).	**Purpose** Changing encryption keys when they reach the end of their cryptoperiod is imperative to minimize the risk of someone obtaining the encryption keys and using them to decrypt data. **Definitions** A cryptoperiod is the time span during which a cryptographic key can be used for its defined purpose. Cryptoperiods are often defined in terms of the period for which the key is active and/or the amount of cipher-text that has been produced by the key. Considerations for defining the cryptoperiod include, but are not limited to, the strength of the underlying algorithm, size or length of the key, risk of key compromise, and the sensitivity of the data being encrypted. **Further Information** *NIST SP 800-57 Part 1, Revision 5, Section 5.3 Cryptoperiods* – provides guidance for establishing the time span during which a specific key is authorized for use by legitimate entities, or the keys for a given system will remain in effect. See Table 1 of *SP 800-57* Part 1 for suggested cryptoperiods for different key types.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.7.5** Key management policies procedures are implemented to include the retirement, replacement, or destruction of keys used to protect stored account data, as deemed necessary when: • The key has reached the end of its defined cryptoperiod. • The integrity of the key has been weakened, including when personnel with knowledge of a cleartext key component leaves the company, or the role for which the key component was known. • The key is suspected of or known to be compromised. Retired or replaced keys are not used for encryption operations. **Customized Approach Objective** Keys are removed from active use when it is suspected or known that the integrity of the key is weakened. **Applicability Notes** If retired or replaced cryptographic keys need to be retained, these keys must be securely archived (for example, by using a key-encryption key).	**Defined Approach Testing Procedures** **3.7.5.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define retirement, replacement, or destruction of keys in accordance with all elements specified in this requirement. **3.7.5.b** Interview personnel to verify that processes are implemented in accordance with all elements specified in this requirement.	**Purpose** Keys that are no longer required, keys with weakened integrity, and keys that are known or suspected to be compromised, should be archived, revoked, and/or destroyed to ensure that the keys can no longer be used. If such keys need to be kept (for example, to support archived encrypted data), they should be strongly protected. **Good Practice** Archived cryptographic keys should be used only for decryption/verification purposes. The encryption solution should provide for and facilitate a process to replace keys that are due for replacement or that are known to be, or suspected of being, compromised. In addition, any keys that are known to be, or suspected of being, compromised should be managed in accordance with the entity's incident response plan per Requirement 12.10.1. **Further Information** Industry best practices for archiving retired keys are outlined in *NIST SP 800-57 Part 1, Revision 5, Section 8.3.1*, and includes maintaining the archive with a trusted third party and storing archived key information separately from operational data.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.7.6** Where manual cleartext cryptographic key-management operations are performed by personnel, key-management policies and procedures are implemented, including managing these operations using split knowledge and dual control.	**Defined Approach Testing Procedures** **3.7.6.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define using split knowledge and dual control. **3.7.6.b** Interview personnel and/or observe processes to verify that manual cleartext keys are managed with split knowledge and dual control.	**Purpose** Split knowledge and dual control of keys are used to eliminate the possibility of a single person having access to the whole key and therefore being able to gain unauthorized access to the data. **Definitions** Split knowledge is a method in which two or more people separately have key components, where each person knows only their own key component, and the individual key components convey no knowledge of other components or of the original cryptographic key. Dual control requires two or more people to authenticate the use of a cryptographic key or perform a key-management function. No single person can access or use the authentication factor (for example, the password, PIN, or key) of another. **Good Practice** Where key components or key shares are used, procedures should ensure that no single custodian ever has access to sufficient key components or shares to reconstruct the cryptographic key. For example, in an m-of-n scheme (for example, Shamir), where only two of any three components are required to reconstruct the cryptographic key, a custodian must not have current or prior knowledge of more than one component. If a custodian was previously assigned component A, which was then reassigned, the custodian should not then be assigned component B or C, as this would give the custodian knowledge of two components and the ability to recreate the key. *(continued on next page)*
Customized Approach Objective Cleartext secret or private keys cannot be known by anyone. Operations involving cleartext keys cannot be carried out by a single person.		
Applicability Notes This control is applicable for manual key-management operations. A cryptographic key that is simply split into two parts does not meet this requirement. Secret or private keys stored as key components or key shares must be generated via one of the following: • Using an approved random number generator and within a secure cryptographic device (SCD), such as a hardware security module (HSM) or PTS-approved point-of-interaction device, **OR** • According to ISO 19592 or equivalent industry standard for generation of secret key shares.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
3.7.6 *(continued)*		**Examples** Key-management operations that might be performed manually include, but are not limited to, key generation, transmission, loading, storage, and destruction. **Further Information** Industry standards for managing key components include: • *NIST SP 800-57* Part 2, Revision 1 -- Recommendation for Key Management: Part 2 – Best Practices for Key Management Organizations [4.6 Keying Material Distribution] • *ISO 11568-2 Banking — Key management (retail) — Part 2*: Symmetric ciphers, their key management and life cycle [4.7.2.3 Key components and 4.9.3 Key components] • *European Payments Council EPC342-08 Guidelines on Cryptographic Algorithms Usage and Key Management* [especially 4.1.4 Key installation].
Defined Approach Requirements **3.7.7** Key management policies and procedures are implemented to include the prevention of unauthorized substitution of cryptographic keys. **Customized Approach Objective** Cryptographic keys cannot be substituted by unauthorized personnel.	**Defined Approach Testing Procedures** **3.7.7.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define prevention of unauthorized substitution of cryptographic keys. **3.7.7.b** Interview personnel and/or observe processes to verify that unauthorized substitution of keys is prevented.	**Purpose** If an attacker is able to substitute an entity's key with a key the attacker knows, the attacker will be able to decrypt all data encrypted with that key. **Good Practice** The encryption solution should not allow for or accept substitution of keys from unauthorized sources or unexpected processes. Controls should include ensuring that individuals with access to key components or shares do not have access to other components or shares that form the necessary threshold to derive the key.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.7.8** Key management policies and procedures are implemented to include that cryptographic key custodians formally acknowledge (in writing or electronically) that they understand and accept their key-custodian responsibilities. **Customized Approach Objective** Key custodians are knowledgeable about their responsibilities in relation to cryptographic operations and can access assistance and guidance when required.	**Defined Approach Testing Procedures** **3.7.8.a** Examine the documented key-management policies and procedures for keys used for protection of stored account data and verify that they define acknowledgments for key custodians in accordance with all elements specified in this requirement. **3.7.8.b** Examine documentation or other evidence showing that key custodians have provided acknowledgments in accordance with all elements specified in this requirement.	**Purpose** This process will help ensure individuals that act as key custodians commit to the key-custodian role and understand and accept the responsibilities. An annual reaffirmation can help remind key custodians of their responsibilities. **Further Information** Industry guidance for key custodians and their roles and responsibilities includes: • *NIST SP 800-130 A Framework for Designing Cryptographic Key Management Systems* [5. Roles and Responsibilities (especially) for Key Custodians] • *ISO 11568-1 Banking -- Key management (retail) -- Part 1*: Principles [5 Principles of key management (especially b)]

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **3.7.9** ***Additional requirement for service providers only:*** Where a service provider shares cryptographic keys with its customers for transmission or storage of account data, guidance on secure transmission, storage and updating of such keys is documented and distributed to the service provider's customers. **Customized Approach Objective** Customers are provided with appropriate key management guidance whenever they receive shared cryptographic keys. **Applicability Notes** This requirement applies only when the entity being assessed is a service provider.	**Defined Approach Testing Procedures** **3.7.9** ***Additional testing procedure for service provider assessments only:*** If the service provider shares cryptographic keys with its customers for transmission or storage of account data, examine the documentation that the service provider provides to its customers to verify it includes guidance on how to securely transmit, store, and update customers' keys in accordance with all elements specified in Requirements 3.7.1 through 3.7.8 above.	**Purpose** Providing guidance to customers on how to securely transmit, store, and update cryptographic keys can help prevent keys from being mismanaged or disclosed to unauthorized entities. **Further Information** Numerous industry standards for key management are cited above in the Guidance for Requirements 3.7.1-3.7.8.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirement 4: Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Sections

4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and understood.

4.2 PAN is protected with strong cryptography during transmission

Overview

The use of strong cryptography provides greater assurance in preserving data confidentiality, integrity, and non-repudiation.

To protect against compromise, PAN must be encrypted during transmission over networks that are easily accessed by malicious individuals, including untrusted and public networks. Misconfigured wireless networks and vulnerabilities in legacy encryption and authentication protocols continue to be targeted by malicious individuals aiming to exploit these vulnerabilities to gain privileged access to cardholder data environments (CDE). Any transmissions of cardholder data over an entity's internal network(s) will naturally bring that network into scope for PCI DSS since that network stores, processes, or transmits cardholder data. Any such networks must be evaluated and assessed against applicable PCI DSS requirements.

Requirement 4 applies to transmissions of PAN unless specifically called out in an individual requirement.

PAN transmissions can be protected by encrypting the data before it is transmitted, or by encrypting the session over which the data is transmitted, or both. While it is not required that strong cryptography be applied at both the data level and the session level, it is recommended.

Refer to *Appendix G* for definitions of "strong cryptography" and other PCI DSS terms.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and understood.		
Defined Approach Requirements **4.1.1** All security policies and operational procedures that are identified in Requirement 4 are: • Documented. • Kept up to date. • In use. • Known to all affected parties. **Customized Approach Objective** Expectations, controls, and oversight for meeting activities within Requirement 4 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.	**Defined Approach Testing Procedures** **4.1.1** Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 4 are managed in accordance with all elements specified in this requirement.	**Purpose** Requirement 4.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 4. While it is important to define the specific policies or procedures called out in Requirement 4, it is equally important to ensure they are properly documented, maintained, and disseminated. **Good Practice** It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. **Definitions** Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives. Policies and procedures, including updates, are actively communicated to all affected personnel, and are supported by operating procedures describing how to perform activities.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **4.1.2** Roles and responsibilities for performing activities in Requirement 4 are documented, assigned, and understood.	**Defined Approach Testing Procedures** **4.1.2.a** Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 4 are documented and assigned. **4.1.2.b** Interview personnel with responsibility for performing activities in Requirement 4 to verify that roles and responsibilities are assigned as documented and are understood.	**Purpose** If roles and responsibilities are not formally assigned, personnel may not be aware of their day-to-day responsibilities and critical activities may not occur. **Good Practice** Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. **Examples** A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 4 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
4.2 PAN is protected with strong cryptography during transmission.		
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose**
4.2.1 Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks: • Only trusted keys and certificates are accepted. • Certificates used to safeguard PAN during transmission over open, public networks are confirmed as valid and are not expired or revoked. *This bullet is a best practice until its effective date; refer to applicability notes below for details.* • The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations. • The encryption strength is appropriate for the encryption methodology in use.	**4.2.1.a** Examine documented policies and procedures and interview personnel to verify processes are defined to include all elements specified in this requirement. **4.2.1.b** Examine system configurations to verify that strong cryptography and security protocols are implemented in accordance with all elements specified in this requirement. **4.2.1.c** Examine cardholder data transmissions to verify that all PAN is encrypted with strong cryptography when it is transmitted over open, public networks. **4.2.1.d** Examine system configurations to verify that keys and/or certificates that cannot be verified as trusted are rejected.	Sensitive information must be encrypted during transmission over public networks because it is easy and common for a malicious individual to intercept and/or divert data while in transit. **Good Practice** The network and data-flow diagrams defined in Requirement 1 are useful resources for identifying all connection points where account data is transmitted or received over open, public networks. While not required, it is considered a good practice for entities to also encrypt PAN over their internal networks, and for entities to establish any new network implementations with encrypted communications. PAN transmissions can be protected by encrypting the data before it is transmitted, or by encrypting the session over which the data is transmitted, or both. While it is not required that strong cryptography be applied at both the data level and the session level, it is strongly recommended. If encrypted at the data level, the cryptographic keys used for protecting the data can be managed in accordance with Requirements 3.6 and 3.7. If the data is encrypted at the session level, designated key custodians should be assigned responsibility for managing transmission keys and certificates. *(continued on next page)*
Customized Approach Objective		
Cleartext PAN cannot be read or intercepted from any transmissions over open, public networks.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes A self-signed certificate may also be acceptable if the certificate is issued by an internal CA within the organization, the certificate's author is confirmed, and the certificate is verified—for example, via hash or signature—and has not expired. *The bullet above (for confirming that certificates used to safeguard PAN during transmission over open, public networks are valid and are not expired or revoked) is a best practice until 31 March 2025, after which it will be required as part of Requirement 4.2.1 and must be fully considered during a PCI DSS assessment.*		Some protocol implementations (such as SSL, SSH v1.0, and early TLS) have known vulnerabilities that an attacker can use to gain access to the cleartext data. It is critical that entities maintain awareness of industry-defined deprecation dates for the cipher suites they are using and are prepared to migrate to newer versions or protocols when older ones are no longer deemed secure. Verifying that certificates are trusted helps ensure the integrity of the secure connection. To be considered trusted, a certificate should be issued from a trusted source, such as a trusted certificate authority (CA), and not be expired. Up-to-date Certificate Revocation Lists (CRLs) or Online Certificate Status Protocol (OCSP) can be used to validate certificates. Techniques to validate certificates may include certificate and public key pinning, where the trusted certificate or a public key is pinned either during development or upon its first use. Entities can also confirm with developers or review source code to ensure that clients and servers reject connections if the certificate is bad. For browser-based TLS certificates, certificate trust can often be verified by clicking on the lock icon that appears next to the address bar. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
4.2.1 *(continued)*		**Examples** Open, public networks include, but are not limited to: • The Internet and • Wireless technologies, including Wi-Fi, Bluetooth, cellular technologies, and satellite communications. **Further Information** Vendor recommendations and industry best practices can be consulted for information about the proper encryption strength specific to the encryption methodology in use. For more information about strong cryptography and secure protocols, see industry standards and best practices such as *NIST SP 800-52* and *SP 800-57*. For more information about trusted keys and certificates, see *NIST Cybersecurity Practice Guide Special Publication 1800-16*, *Securing Web Transactions: Transport Layer Security (TLS) Server Certificate Management.*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **4.2.1.1** An inventory of the entity's trusted keys and certificates used to protect PAN during transmission is maintained.	**Defined Approach Testing Procedures** **4.2.1.1.a** Examine documented policies and procedures to verify processes are defined for the entity to maintain an inventory of its trusted keys and certificates.	**Purpose** The inventory of trusted keys helps the entity keep track of the algorithms, protocols, key strength, key custodians, and key expiry dates. This enables the entity to respond quickly to vulnerabilities discovered in encryption software, certificates, and cryptographic algorithms. **Good Practice** For certificates, the inventory should include the issuing CA and certification expiration date.
	4.2.1.1.b Examine the inventory of trusted keys and certificates to verify it is kept up to date.	
Customized Approach Objective All keys and certificates used to protect PAN during transmission are identified and confirmed as trusted.		
Applicability Notes *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **4.2.1.2** Wireless networks transmitting PAN or connected to the CDE use industry best practices to implement strong cryptography for authentication and transmission. **Customized Approach Objective** Cleartext PAN cannot be read or intercepted from wireless network transmissions.	**Defined Approach Testing Procedures** **4.2.1.2** Examine system configurations to verify that wireless networks transmitting PAN or connected to the CDE use industry best practices to implement strong cryptography for authentication and transmission.	**Purpose** Since wireless networks do not require physical media to connect, it is important to establish controls limiting who can connect and what transmission protocols will be used. Malicious users use free and widely available tools to eavesdrop on wireless communications. Use of strong cryptography can help limit disclosure of sensitive information across wireless networks. Wireless networks present unique risks to an organization; therefore, they must be identified and protected according to industry requirements. Strong cryptography for authentication and transmission of PAN is required to prevent malicious users from gaining access to the wireless network or utilizing wireless networks to access other internal networks or data. **Good Practice** Wireless networks should not permit fallback or downgrade to an insecure protocol or lower encryption strength that does not meet the intent of strong cryptography. **Further Information** Review the vendor's specific documentation for more details on the choice of protocols, configurations, and settings related to cryptography.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **4.2.2** PAN is secured with strong cryptography whenever it is sent via end-user messaging technologies.	**Defined Approach Testing Procedures** **4.2.2.a** Examine documented policies and procedures to verify that processes are defined to secure PAN with strong cryptography whenever sent over end-user messaging technologies. **4.2.2.b** Examine system configurations and vendor documentation to verify that PAN is secured with strong cryptography whenever it is sent via end-user messaging technologies.	**Purpose** End-user messaging technologies typically can be easily intercepted by packet-sniffing during delivery across internal and public networks. **Good Practice** The use of end-user messaging technology to send PAN should only be considered where there is a defined business need and should be controlled through the Acceptable Use Policies for end-user technologies defined by the entity according to Requirement 12.2.1. **Examples** E-mail, instant messaging, SMS, and chat are examples of the type of end-user messaging technology that this requirement refers to.
Customized Approach Objective Cleartext PAN cannot be read or intercepted from transmissions using end-user messaging technologies.		
Applicability Notes This requirement also applies if a customer, or other third party, requests that PAN is sent to them via end-user messaging technologies. There could be occurrences where an entity receives unsolicited cardholder data via an insecure communication channel that was not intended for transmissions of sensitive data. In this situation, the entity can choose to either include the channel in the scope of their CDE and secure it according to PCI DSS or delete the cardholder data and implement measures to prevent the channel from being used for cardholder data.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirement 6: Develop and Maintain Secure Systems and Software

Sections

6.1 Processes and mechanisms for developing and maintaining secure systems and software are defined and understood.

6.2 Bespoke and custom software are developed securely.

6.3 Security vulnerabilities are identified and addressed.

6.4 Public-facing web applications are protected against attacks.

6.5 Changes to all system components are managed securely.

Overview

Actors with bad intentions can use security vulnerabilities to gain privileged access to systems. Many of these vulnerabilities are fixed by vendor provided security patches, which must be installed by the entities that manage the systems. All system components must have all appropriate software patches to protect against the exploitation and compromise of account data by malicious individuals and malicious software.

Appropriate software patches are those patches that have been evaluated and tested sufficiently to determine that the patches do not conflict with existing security configurations. For bespoke and custom software, numerous vulnerabilities can be avoided by applying software lifecycle (SLC) processes and secure coding techniques.

Code repositories that store application code, system configurations, or other configuration data that can impact the security of cardholder data and/or sensitive authentication data are in scope for PCI DSS assessments.

See *Relationship between PCI DSS and PCI SSC Software Standards* on page 7 for information about the use of PCI SSC-validated software and software vendors, and how use of PCI SSC's software standards may help with meeting controls in Requirement 6.

Refer to *Appendix G* for definitions of PCI DSS terms.

***Note**: Requirement 6 applies to all system components, except for section 6.2 for developing software securely, which applies only to bespoke and custom software used on any system component included in or connected to the CDE.*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.1 Processes and mechanisms for developing and maintaining secure systems and software are defined and understood.		
Defined Approach Requirements **6.1.1** All security policies and operational procedures that are identified in Requirement 6 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	**Defined Approach Testing Procedures** **6.1.1** Examine documentation and interview personnel to verify that security policies and operational procedures identified in Requirement 6 are managed in accordance with all elements specified in this requirement.	**Purpose** Requirement 6.1.1 is about effectively managing and maintaining the various policies and procedures specified throughout Requirement 6. While it is important to define the specific policies or procedures called out in Requirement 6, it is equally important to ensure they are properly documented, maintained, and disseminated. **Good Practice** It is important to update policies and procedures as needed to address changes in processes, technologies, and business objectives. For this reason, consider updating these documents as soon as possible after a change occurs and not only on a periodic cycle. **Definitions** Security policies define the entity's security objectives and principles. Operational procedures describe how to perform activities, and define the controls, methods, and processes that are followed to achieve the desired result in a consistent manner and in accordance with policy objectives.
Customized Approach Objective Expectations, controls, and oversight for meeting activities within Requirement 6 are defined and adhered to by affected personnel. All supporting activities are repeatable, consistently applied, and conform to management's intent.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.1.2** Roles and responsibilities for performing activities in Requirement 6 are documented, assigned, and understood.	**Defined Approach Testing Procedures** **6.1.2.a** Examine documentation to verify that descriptions of roles and responsibilities for performing activities in Requirement 6 are documented and assigned. **6.1.2.b** Interview personnel responsible for performing activities in Requirement 6 to verify that roles and responsibilities are assigned as documented and are understood.	**Purpose** If roles and responsibilities are not formally assigned, systems will not be securely maintained, and their security level will be reduced. **Good Practice** Roles and responsibilities may be documented within policies and procedures or maintained within separate documents. As part of communicating roles and responsibilities, entities can consider having personnel acknowledge their acceptance and understanding of their assigned roles and responsibilities. **Examples** A method to document roles and responsibilities is a responsibility assignment matrix that includes who is responsible, accountable, consulted, and informed (also called a RACI matrix).
Customized Approach Objective Day-to-day responsibilities for performing all the activities in Requirement 6 are allocated. Personnel are accountable for successful, continuous operation of these requirements.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.2 Bespoke and custom software are developed securely.		
Defined Approach Requirements **6.2.1** Bespoke and custom software are developed securely, as follows: • Based on industry standards and/or best practices for secure development. • In accordance with PCI DSS (for example, secure authentication and logging). • Incorporating consideration of information security issues during each stage of the software development lifecycle. **Customized Approach Objective** Bespoke and custom software is developed in accordance with PCI DSS and secure development processes throughout the software lifecycle. **Applicability Notes** This applies to all software developed for or by the entity for the entity's own use. This includes both bespoke and custom software. This does not apply to third-party software.	**Defined Approach Testing Procedures** **6.2.1** Examine documented software development procedures to verify that processes are defined that include all elements specified in this requirement.	**Purpose** Without the inclusion of security during the requirements definition, design, analysis, and testing phases of software development, security vulnerabilities can be inadvertently or maliciously introduced into the production environment. **Good Practice** Understanding how sensitive data is handled by the application—including when stored, transmitted, and in memory—can help identify where data needs to be protected. PCI DSS requirements must be considered when developing software to meet those requirements by design, rather than trying to retrofit the software later. **Examples** Secure software lifecycle management methodologies and frameworks include PCI Software Security Framework, BSIMM, OPENSAMM, and works from NIST, ISO, and SAFECode.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Having staff knowledgeable in secure coding methods, including techniques defined in Requirement 6.2.4, will help minimize the number of security vulnerabilities introduced through poor coding practices. **Good Practice** Training for developers may be provided in-house or by third parties. Training should include, but is not limited to, development languages in use, secure software design, secure coding techniques, use of techniques/methods for finding vulnerabilities in code, processes to prevent reintroducing previously resolved vulnerabilities, and how to use any automated security testing tools for detecting vulnerabilities in software. As industry-accepted secure coding practices change, organizational coding practices and developer training may need to be updated to address new threats.
6.2.2 Software development personnel working on bespoke and custom software are trained at least once every 12 months as follows: • On software security relevant to their job function and development languages. • Including secure software design and secure coding techniques. • Including, if security testing tools are used, how to use the tools for detecting vulnerabilities in software.	**6.2.2.a** Examine software development procedures to verify that processes are defined for training of software development personnel developing bespoke and custom software that includes all elements specified in this requirement.	
Customized Approach Objective	**6.2.2.b** Examine training records and interview personnel to verify that software development personnel working on bespoke and custom software received software security training that is relevant to their job function and development languages in accordance with all elements specified in this requirement.	
Software development personnel remain knowledgeable about secure development practices; software security; and attacks against the languages, frameworks, or applications they develop. Personnel are able to access assistance and guidance when required.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.2.3** Bespoke and custom software is reviewed prior to being released into production or to customers, to identify and correct potential coding vulnerabilities, as follows: • Code reviews ensure code is developed according to secure coding guidelines. • Code reviews look for both existing and emerging software vulnerabilities. • Appropriate corrections are implemented prior to release. **Customized Approach Objective** Bespoke and custom software cannot be exploited via coding vulnerabilities. **Applicability Notes** This requirement for code reviews applies to all bespoke and custom software (both internal and public facing), as part of the system development lifecycle. Public-facing web applications are also subject to additional controls, to address ongoing threats and vulnerabilities after implementation, as defined at PCI DSS Requirement 6.4. Code reviews may be performed using either manual or automated processes, or a combination of both.	**Defined Approach Testing Procedures** **6.2.3.a** Examine documented software development procedures and interview responsible personnel to verify that processes are defined that require all bespoke and custom software to be reviewed in accordance with all elements specified in this requirement. **6.2.3.b** Examine evidence of changes to bespoke and custom software to verify that the code changes were reviewed in accordance with all elements specified in this requirement.	**Purpose** Security vulnerabilities in bespoke and custom software are commonly exploited by malicious individuals to gain access to a network and compromise account data. Vulnerable code is far more difficult and expensive to address after it has been deployed or released into production environments. Requiring a formal review and signoff by management prior to release helps to ensure that code is approved and has been developed in accordance with policies and procedures. **Good Practice** The following items should be considered for inclusion in code reviews: • Searching for undocumented features (implant tools, backdoors). • Confirming that software securely uses external components' functions (libraries, frameworks, APIs, etc.). For example, if a third-party library providing cryptographic functions is used, verify that it was integrated securely. • Checking for correct use of logging to prevent sensitive data from getting into logs. • Analysis of insecure code structures that may contain potential vulnerabilities related to common software attacks identified in Requirement 6.2.4. • Checking the application's behavior to detect logical vulnerabilities.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.2.3.1** If manual code reviews are performed for bespoke and custom software prior to release to production, code changes are: • Reviewed by individuals other than the originating code author, and who are knowledgeable about code-review techniques and secure coding practices. • Reviewed and approved by management prior to release.	**Defined Approach Testing Procedures** **6.2.3.1.a** If manual code reviews are performed for bespoke and custom software prior to release to production, examine documented software development procedures and interview responsible personnel to verify that processes are defined for manual code reviews to be conducted in accordance with all elements specified in this requirement. **6.2.3.1.b** Examine evidence of changes to bespoke and custom software and interview personnel to verify that manual code reviews were conducted in accordance with all elements specified in this requirement.	**Purpose** Having code reviewed by someone other than the original author, who is both experienced in code reviews and knowledgeable about secure coding practices, minimizes the possibility that code containing security or logic errors that could affect the security of cardholder data is released into a production environment. Requiring management approval that the code was reviewed limits the ability for the process to be bypassed. **Good Practice** Having a formal review methodology and review checklists has been found to improve the quality of the code review process. Code review is a tiring process, and for this reason, it is most effective when reviewers only review small amounts of code at a time. To maintain the effectiveness of code reviews, it is beneficial to monitor the general workload of reviewers and to have them review applications they are familiar with. Code reviews may be performed using either manual or automated processes, or a combination of both. Entitles that rely solely on manual code review should ensure that reviewers maintain their skills through regular training as new vulnerabilities are found, and new secure coding methods are recommended. **Further Information** See the *OWASP Code Review Guide*.
Customized Approach Objective The manual code review process cannot be bypassed and is effective at discovering security vulnerabilities.		
Applicability Notes Manual code reviews can be conducted by knowledgeable internal personnel or knowledgeable third-party personnel. An individual that has been formally granted accountability for release control and who is neither the original code author nor the code reviewer fulfills the criteria of being management.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	
6.2.4 Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software, including but not limited to the following: • Injection attacks, including SQL, LDAP, XPath, or other command, parameter, object, fault, or injection-type flaws. • Attacks on data and data structures, including attempts to manipulate buffers, pointers, input data, or shared data. • Attacks on cryptography usage, including attempts to exploit weak, insecure, or inappropriate cryptographic implementations, algorithms, cipher suites, or modes of operation. • Attacks on business logic, including attempts to abuse or bypass application features and functionalities through the manipulation of APIs, communication protocols and channels, client-side functionality, or other system/application functions and resources. This includes cross-site scripting (XSS) and cross-site request forgery (CSRF). • Attacks on access control mechanisms, including attempts to bypass or abuse identification, authentication, or authorization mechanisms, or attempts to exploit weaknesses in the implementation of such mechanisms. • Attacks via any "high-risk" vulnerabilities identified in the vulnerability identification process, as defined in Requirement 6.3.1.	**6.2.4** Examine documented procedures and interview responsible software development personnel to verify that software engineering techniques or other methods are defined and in use by developers of bespoke and custom software to prevent or mitigate all common software attacks as specified in this requirement.	**Purpose** Detecting or preventing common errors that result in vulnerable code as early as possible in the software development process lowers the probability that such errors make it through to production and lead to a compromise. Having formal engineering techniques and tools embedded in the development process will catch these errors early. This philosophy is sometimes called "shifting security left." **Good Practice** For both bespoke and custom software, the entity must ensure that code is developed focusing on the prevention or mitigation of common software attacks, including: • Attempts to exploit common coding vulnerabilities (bugs). • Attempts to exploit software design flaws. • Attempts to exploit implementation/configuration flaws. • Enumeration attacks – automated attacks that are actively exploited in payments and abuse identification, authentication, or authorization mechanisms. See the *PCI Perspectives blog article "Beware of Account Testing Attacks*." *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Customized Approach Objective Bespoke and custom software cannot be exploited via common attacks and related vulnerabilities. **Applicability Notes** This applies to all software developed for or by the entity for the entity's own use. This includes both bespoke and custom software. This does not apply to third-party software.		Researching and documenting software engineering techniques or other methods helps to define how software developers prevent or mitigate various software attacks by features or countermeasures they build into software. This might include identification/authentication mechanisms, access control, input validation routines, etc. Developers should be familiar with different types of vulnerabilities and potential attacks and use measures to avoid potential attack vectors when developing code. **Examples** Techniques include automated processes and practices that scan code early in the development cycle when code is checked in to confirm the vulnerabilities are not present.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.3 Security vulnerabilities are identified and addressed.		
Defined Approach Requirements **6.3.1** Security vulnerabilities are identified and managed as follows: • New security vulnerabilities are identified using industry-recognized sources for security vulnerability information, including alerts from international and national computer emergency response teams (CERTs). • Vulnerabilities are assigned a risk ranking based on industry best practices and consideration of potential impact. • Risk rankings identify, at a minimum, all vulnerabilities considered to be a high-risk or critical to the environment. • Vulnerabilities for bespoke and custom, and third-party software (for example operating systems and databases) are covered. **Customized Approach Objective** New system and software vulnerabilities that may impact the security of cardholder data and/or sensitive authentication data are monitored, cataloged, and risk assessed.	**Defined Approach Testing Procedures** **6.3.1.a** Examine policies and procedures for identifying and managing security vulnerabilities to verify that processes are defined in accordance with all elements specified in this requirement. **6.3.1.b** Interview responsible personnel, examine documentation, and observe processes to verify that security vulnerabilities are identified and managed in accordance with all elements specified in this requirement.	**Purpose** Classifying the risks (for example, as critical, high, medium, or low) allows organizations to identify, prioritize, and address the highest risk items more quickly and reduce the likelihood that vulnerabilities posing the greatest risk will be exploited. **Good Practice** Methods for evaluating vulnerabilities and assigning risk ratings will vary based on an organization's environment and risk-assessment strategy. When an entity is assigning its risk rankings, it should consider using a formal, objective, justifiable methodology that accurately portrays the risks of the vulnerabilities pertinent to the organization and translates to an appropriate entity-assigned priority for resolution. Risk rankings should, at a minimum, identify all vulnerabilities considered to be a "high risk" to the environment. In addition to the risk ranking, vulnerabilities may be considered "critical" if they pose an imminent threat to the environment, impact critical systems, and/or would result in a potential compromise if not addressed. Examples of critical systems may include security systems, public-facing devices and systems, databases, and other systems that store, process, or transmit cardholder data. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement is not achieved by, and is in addition to, performing vulnerability scans according to Requirements 11.3.1 and 11.3.2. This requirement is for a process to actively monitor industry sources for vulnerability information and for the entity to determine the risk ranking to be associated with each vulnerability.		An organization's processes for managing vulnerabilities should be integrated with other management processes—for example, risk management, change management, patch management, incident response, application security, as well as proper monitoring and logging of these processes. This process should include multiple sources of vulnerability information, including industry-recognized vulnerability databases (for example, the US National Vulnerability Database), CERTs, RSS feeds, information received from vendors and third parties, and vulnerabilities identified via internal and external vulnerability scans (Requirements 11.3.1 and 11.3.2). This will help to ensure all vulnerabilities are properly identified and addressed. Processes should support ongoing evaluation of vulnerabilities. For example, a vulnerability initially identified as low risk could become a higher risk later. Additionally, vulnerabilities individually considered to be low or medium risk, could collectively pose a high or critical risk if present on the same system, or if exploited on a low-risk system that could result in access to the CDE. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.3.1 *(continued)*		**Examples** Some organizations that issue alerts to advise entities about urgent vulnerabilities requiring immediate patches/updates are national Computer Emergency Readiness/Response Teams (CERTs) and vendors. Criteria for ranking vulnerabilities may include criticality of a vulnerability identified in an alert from Forum of Incident Response and Security Teams (FIRST) or a CERT, consideration of the CVSS score, the classification by the vendor, and/or type of systems affected. **Further Information** Trustworthy sources for vulnerability information include vendor websites, industry newsgroups, mailing lists, etc. If software is developed in-house, the internal development team should also consider sources of information about new vulnerabilities that may affect internally developed applications. Other methods to ensure new vulnerabilities are identified include solutions that automatically recognize and alert upon detection of unusual behavior. Processes should account for widely published exploits as well as “zero-day” attacks, which target previously unknown vulnerabilities. For bespoke and custom software, the organization may obtain information about libraries, frameworks, compilers, programming languages, etc. from public trusted sources (for example, special resources and resources from component developers). The organization may also independently analyze third-party components and identify vulnerabilities. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.3.1 *(continued)*		For control over in-house developed software, the organization may receive such information from external sources. The organization can consider using a “bug bounty” program where it posts information (for example, on its website) so third parties can contact the organization with vulnerability information. External sources may include independent investigators or companies that report to the organization about identified vulnerabilities and may include sources such as the Common Vulnerability Scoring System (CVSS) or the OWASP Risk Rating Methodology.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.3.2** An inventory of bespoke and custom software, and third-party software components incorporated into bespoke and custom software is maintained to facilitate vulnerability and patch management.	**Defined Approach Testing Procedures** **6.3.2.a** Examine documentation and interview personnel to verify that an inventory of bespoke and custom software and third-party software components incorporated into bespoke and custom software is maintained, and that the inventory is used to identify and address vulnerabilities.	**Purpose** Identifying and listing all the entity's bespoke and custom software, and any third-party software that is incorporated into the entity's bespoke and custom software enables the entity to manage vulnerabilities and patches. Vulnerabilities in third-party components (including libraries, APIs, etc.) embedded in an entity's software also renders those applications vulnerable to attacks. Knowing which third-party components are used in the entity's software and monitoring the availability of security patches to address known vulnerabilities is critical to ensuring the security of the software. **Good Practice** An entity's inventory should cover all payment software components and dependencies, including supported execution platforms or environments, third-party libraries, services, and other required functionalities. There are many different types of solutions that can help with managing software inventories, such as software composition analysis tools, application discovery tools, and mobile device management.
Customized Approach Objective Known vulnerabilities in third-party software components cannot be exploited in bespoke and custom software.	**6.3.2.b** Examine software documentation, including for bespoke and custom software that integrates third-party software components, and compare it to the inventory to verify that the inventory includes the bespoke and custom software and third-party software components.	
Applicability Notes *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.3.3** All system components are protected from known vulnerabilities by installing applicable security patches/updates as follows: • Patches/updates for critical vulnerabilities (identified according to the risk ranking process at Requirement 6.3.1) are installed within one month of release. • All other applicable security patches/updates are installed within an appropriate time frame as determined by the entity's assessment of the criticality of the risk to the environment as identified according to the risk ranking process at Requirement 6.3.1. **Customized Approach Objective** System components cannot be compromised via the exploitation of a known vulnerability.	**Defined Approach Testing Procedures** **6.3.3.a** Examine policies and procedures to verify processes are defined for addressing vulnerabilities by installing applicable security patches/updates in accordance with all elements specified in this requirement. **6.3.3.b** Examine system components and related software and compare the list of installed security patches/updates to the most recent security patch/update information to verify vulnerabilities are addressed in accordance with all elements specified in this requirement.	**Purpose** New exploits are constantly being discovered, and these can permit attacks against systems that have previously been considered secure. If the most recent security patches/updates are not implemented on critical systems as soon as possible, a malicious actor can use these exploits to attack or disable a system or gain access to sensitive data. **Good Practice** Prioritizing security patches/updates for critical infrastructure ensures that high-priority systems and devices are protected from vulnerabilities as soon as possible after a patch is released. An entity's patching cadence should factor in any re-evaluation of vulnerabilities and subsequent changes in the criticality of a vulnerability per Requirement 6.3.1. For example, a vulnerability initially identified as low risk could become a higher risk later. Additionally, vulnerabilities individually considered to be low or medium risk could collectively pose a high or critical risk if present on the same system, or if exploited on a low-risk system that could result in access to the CDE. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.3.3 *(continued)*		It is recommended that the entity complete a targeted risk analysis (TRA) according to PCI DSS Requirement 12.3.1 to document the frequency of installing all other applicable security patches/updates. This TRA would include consideration of the entity's assessment of the criticality of the risk to their environment as identified in the risk ranking process at Requirement 6.3.1. **Examples** An example time frame for installation of patches/updates could be 60 days for high-risk vulnerabilities and 90 days for others, as determined by the entity's assessment of risk.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.4 Public-facing web applications are protected against attacks.		
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Public-facing web applications are those that are available to the public (not only for internal use). These applications are primary targets for attackers, and poorly coded web applications provide an easy path for attackers to gain access to sensitive data and systems. **Good Practice** Manual or automated vulnerability security assessment tools or methods review and/or test the application for vulnerabilities. Common assessment tools include specialized web scanners that perform automatic analysis of web application protection. When using automated technical solutions, it is important to include processes that facilitate timely responses to alerts generated by the solutions so that any detected attacks can be mitigated. **Examples** A web application firewall (WAF) installed in front of public-facing web applications to check all traffic is an example of an automated technical solution that detects and prevents web-based attacks (for example, the attacks included in Requirement 6.2.4). WAFs filter and block non-essential traffic at the application layer. A properly configured WAF helps to prevent application-layer attacks on applications that are improperly coded or configured. *(continued on next page)*
6.4.1 For public-facing web applications, new threats and vulnerabilities are addressed on an ongoing basis and these applications are protected against known attacks as follows: • Reviewing public-facing web applications via manual or automated application vulnerability security assessment tools or methods as follows: – At least once every 12 months and after significant changes. – By an entity that specializes in application security. – Including, at a minimum, all common software attacks in Requirement 6.2.4. – All vulnerabilities are ranked in accordance with requirement 6.3.1. – All vulnerabilities are corrected. – The application is re-evaluated after the corrections. **OR** • Installing an automated technical solution(s) that continually detects and prevents web-based attacks as follows: – Installed in front of public-facing web applications to detect and prevent web-based attacks. – Actively running and up to date as applicable. – Generating audit logs. – Configured to either block web-based attacks or generate an alert that is immediately investigated.	**6.4.1** For public-facing web applications, ensure that either one of the required methods is in place as follows: • If manual or automated vulnerability security assessment tools or methods are in use, examine documented processes, interview personnel, and examine records of application security assessments to verify that public-facing web applications are reviewed in accordance with all elements of this requirement specific to the tool/method. **OR** • If an automated technical solution(s) is installed that continually detects and prevents web-based attacks, examine the system configuration settings and audit logs, and interview responsible personnel to verify that the automated technical solution(s) is installed in accordance with all elements of this requirement specific to the solution(s).	

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Customized Approach Objective Public-facing web applications are protected against malicious attacks. **Applicability Notes** This assessment is not the same as the vulnerability scans performed for Requirement 11.3.1 and 11.3.2. *This requirement will be superseded by Requirement 6.4.2 after 31 March 2025 when Requirement 6.4.2 becomes effective.*		Another example of an automated technical solution is Runtime Application Self-Protection (RASP) technologies. When implemented correctly, RASP solutions can detect and block anomalous behavior by the software during execution. While WAFs typically monitor the application perimeter, RASP solutions monitor and block behavior within the application.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.4.2** For public-facing web applications, an automated technical solution is deployed that continually detects and prevents web-based attacks, with at least the following: • Is installed in front of public-facing web applications and is configured to detect and prevent web-based attacks. • Actively running and up to date as applicable. • Generating audit logs. • Configured to either block web-based attacks or generate an alert that is immediately investigated. **Customized Approach Objective** Public-facing web applications are protected in real time against malicious attacks. **Applicability Notes** This new requirement will replace Requirement 6.4.1 once its effective date is reached. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*	**Defined Approach Testing Procedures** **6.4.2** For public-facing web applications, examine the system configuration settings and audit logs, and interview responsible personnel to verify that an automated technical solution that detects and prevents web-based attacks is in place in accordance with all elements specified in this requirement.	**Purpose** Public-facing web applications are primary targets for attackers, and poorly coded web applications provide an easy path for attackers to gain access to sensitive data and systems. **Good Practice** When using automated technical solutions, it is important to include processes that facilitate timely responses to alerts generated by the solutions so that any detected attacks can be mitigated. Such solutions may also be used to automate mitigation, for example rate-limiting controls, which can be implemented to mitigate against brute-force attacks and enumeration attacks. **Examples** A web application firewall (WAF), which can be either on-premise or cloud-based, installed in front of public-facing web applications to check all traffic, is an example of an automated technical solution that detects and prevents web-based attacks (for example, the attacks included in Requirement 6.2.4). WAFs filter and block non-essential traffic at the application layer. A properly configured WAF helps to prevent application-layer attacks on applications that are improperly coded or configured.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.4.3** All payment page scripts that are loaded and executed in the consumer's browser are managed as follows: • A method is implemented to confirm that each script is authorized. • A method is implemented to assure the integrity of each script. • An inventory of all scripts is maintained with written business or technical justification as to why each is necessary. **Customized Approach Objective** Unauthorized code cannot be executed in the payment page as it is rendered in the consumer's browser.	**Defined Approach Testing Procedures** **6.4.3.a** Examine policies and procedures to verify that processes are defined for managing all payment page scripts that are loaded and executed in the consumer's browser, in accordance with all elements specified in this requirement. **6.4.3.b** Interview responsible personnel and examine inventory records and system configurations to verify that all payment page scripts that are loaded and executed in the consumer's browser are managed in accordance with all elements specified in this requirement.	**Purpose** Scripts loaded and executed in the payment page can have their functionality altered without the entity's knowledge and can also have the functionality to load additional external scripts (for example, advertising and tracking, tag management systems). Such seemingly harmless scripts can be used by potential attackers to upload malicious scripts that can read and exfiltrate cardholder data from the consumer browser. Ensuring that the functionality of all such scripts is understood to be necessary for the operation of the payment page minimizes the number of scripts that could be tampered with. Ensuring that scripts have been explicitly authorized reduces the probability of unnecessary scripts being added to the payment page without appropriate management approval. Where it is impractical for such authorization to occur before a script is changed or a new script is added to the page, the authorization should be confirmed as soon as possible after a change is made. Using techniques to prevent tampering with the script will minimize the probability of the script being modified to carry out unauthorized behavior, such as skimming the cardholder data from the payment page. *(continued on next page)*

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Applicability Notes This requirement applies to all scripts loaded from the entity's environment and scripts loaded from third and fourth parties. This requirement also applies to scripts in the entity's webpage(s) that includes a TPSP's/payment processor's embedded payment page/form (for example, one or more inline frames or iframes). This requirement does not apply to an entity for scripts in a TPSP's/payment processor's embedded payment page/form (for example, one or more iframes), where the entity includes a TPSP's/payment processor's payment page/form on its webpage. Scripts in the TPSP's/payment processor's embedded payment page/form are the responsibility of the TPSP/payment processor to manage in accordance with this requirement. *This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.*		**Good Practice** Scripts may be authorized by manual or automated (e.g., workflow) processes. Where the payment page will be loaded into an inline frame (iframe), restricting the location that the payment page can be loaded from, using the parent page's Content Security Policy (CSP) can help prevent unauthorized content being substituted for the payment page. Where an entity includes a TPSP's/payment processor's embedded payment page/form on its webpage, the entity should expect the TPSP/payment processor to provide evidence that the TPSP/payment processor is meeting this requirement, in accordance with the TPSP's/payment processor's PCI DSS assessment and Requirement 12.9. **Examples** The integrity of scripts can be enforced by several different mechanisms including, but not limited to: • Sub-resource integrity (SRI), which allows the consumer browser to validate that a script has not been tampered with. • A CSP, which limits the locations the consumer browser can load a script from and transmit account data to. • Proprietary script or tag-management systems, which can prevent malicious script execution.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
6.5 Changes to all system components are managed securely.		
Defined Approach Requirements **6.5.1** Changes to all system components in the production environment are made according to established procedures that include: • Reason for, and description of, the change. • Documentation of security impact. • Documented change approval by authorized parties. • Testing to verify that the change does not adversely impact system security. • For bespoke and custom software changes, all updates are tested for compliance with Requirement 6.2.4 before being deployed into production. • Procedures to address failures and return to a secure state. **Customized Approach Objective** All changes are tracked, authorized, and evaluated for impact and security, and changes are managed to avoid unintended effects to the security of system components.	**Defined Approach Testing Procedures** **6.5.1.a** Examine documented change control procedures to verify procedures are defined for changes to all system components in the production environment to include all elements specified in this requirement. **6.5.1.b** Examine recent changes to system components and trace those changes back to related change control documentation. For each change examined, verify the change is implemented in accordance with all elements specified in this requirement.	**Purpose** Change management procedures must be applied to all changes—including the addition, removal, or modification of any system component—in the production environment. It is important to document the reason for a change and the change description so that relevant parties understand and agree the change is needed. Likewise, documenting the impacts of the change allows all affected parties to plan appropriately for any processing changes. **Good Practice** Approval by authorized parties confirms that the change is legitimate and that the change is sanctioned by the organization. Changes should be approved by individuals with the appropriate authority and knowledge to understand the impact of the change. Thorough testing by the entity confirms that the security of the environment is not reduced by implementing a change and that all existing security controls either remain in place or are replaced with equal or stronger security controls after the change. The specific testing to be performed will vary according to the type of change and system component(s) affected. For each change, it is important to have documented procedures that address any failures and provide instructions on how to return to a secure state in case the change fails or adversely affects the security of an application or system. These procedures will allow the application or system to be restored to its previous secure state.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.5.2** Upon completion of a significant change, all applicable PCI DSS requirements are confirmed to be in place on all new or changed systems and networks, and documentation is updated as applicable. **Customized Approach Objective** All system components are verified after a significant change to be compliant with the applicable PCI DSS requirements. **Applicability Notes** These significant changes should also be captured and reflected in the entity's annual PCI DSS scope confirmation activity per Requirement 12.5.2.	**Defined Approach Testing Procedures** **6.5.2** Examine documentation for significant changes, interview personnel, and observe the affected systems/networks to verify that the entity confirmed applicable PCI DSS requirements were in place on all new or changed systems and networks and that documentation was updated as applicable.	**Purpose** Having processes to analyze significant changes helps ensure that all appropriate PCI DSS controls are applied to any systems or networks added or changed within the in-scope environment, and that PCI DSS requirements continue to be met to secure the environment. **Good Practice** Building this validation into change management processes helps ensure that device inventories and configuration standards are kept up to date and security controls are applied where needed. **Examples** Applicable PCI DSS requirements that could be impacted include, but are not limited to: • Network and data-flow diagrams are updated to reflect changes. • Systems are configured per configuration standards, with all default passwords changed and unnecessary services disabled. • Systems are protected with required controls—for example, file integrity monitoring (FIM), anti-malware, patches, and audit logging. • Sensitive authentication data is not stored, and all account data storage is documented and incorporated into data retention policy and procedures. • New systems are included in the quarterly vulnerability scanning process. • Systems are scanned for internal and external vulnerabilities after significant changes per Requirements 11.3.1.3 and 11.3.2.1.

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Due to the constantly changing state of pre-production environments, they are often less secure than the production environment. **Good Practice** Organizations must clearly understand which environments are test environments or development environments and how these environments interact on the level of networks and applications. **Definitions** Pre-production environments include development, testing, user acceptance testing (UAT), etc. Even where production infrastructure is used to facilitate testing or development, production environments still need to be separated (logically or physically) from pre-production functionality such that vulnerabilities introduced as a result of pre-production activities do not adversely affect production systems.
6.5.3 Pre-production environments are separated from production environments and the separation is enforced with access controls.	**6.5.3.a** Examine policies and procedures to verify that processes are defined for separating the pre-production environment from the production environment via access controls that enforce the separation.	
	6.5.3.b Examine network documentation and configurations of network security controls to verify that the pre-production environment is separate from the production environment(s).	
Customized Approach Objective	**6.5.3.c** Examine access control settings to verify that access controls are in place to enforce separation between the pre-production and production environment(s).	
Pre-production environments cannot introduce risks and vulnerabilities into production environments.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.5.4** Roles and functions are separated between production and pre-production environments to provide accountability such that only reviewed and approved changes are deployed.	**Defined Approach Testing Procedures** **6.5.4.a** Examine policies and procedures to verify that processes are defined for separating roles and functions to provide accountability such that only reviewed and approved changes are deployed. **6.5.4.b** Observe processes and interview personnel to verify implemented controls separate roles and functions and provide accountability such that only reviewed and approved changes are deployed.	**Purpose** The goal of separating roles and functions between production and pre-production environments is to reduce the number of personnel with access to the production environment and account data and thereby minimize risk of unauthorized, unintentional, or inappropriate access to data and system components and help ensure that access is limited to those individuals with a business need for such access. The intent of this control is to separate critical activities to provide oversight and review to catch errors and minimize the chances of fraud or theft (since two people would need to collude in order to hide an activity). Separating roles and functions, also referred to as separation or segregation of duties, is a key internal control concept to protect an entity's assets.
Customized Approach Objective Job roles and accountability that differentiate between pre-production and production activities are defined and managed to minimize the risk of unauthorized, unintentional, or inappropriate actions.		
Applicability Notes In environments with limited personnel where individuals perform multiple roles or functions, this same goal can be achieved with additional procedural controls that provide accountability. For example, a developer may also be an administrator that uses an administrator-level account with elevated privileges in the development environment and, for their developer role, they use a separate account with user-level access to the production environment.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements	**Defined Approach Testing Procedures**	**Purpose** Use of live PANs outside of protected CDEs provides malicious individuals with the opportunity to gain unauthorized access to cardholder data. **Definitions** Live PANs refer to valid PANs (not test PANs) issued by, or on behalf of, a payment brand. Additionally, when payment cards expire, the same PAN is often reused with a different expiry date. All PANs must be verified as being unable to conduct payment transactions or pose fraud risk to the payment system before they are excluded from PCI DSS scope. It is the responsibility of the entity to confirm that PANs are not live.
6.5.5 Live PANs are not used in pre-production environments, except where those environments are included in the CDE and protected in accordance with all applicable PCI DSS requirements.	**6.5.5.a** Examine policies and procedures to verify that processes are defined for not using live PANs in pre-production environments, except where those environments are in a CDE and protected in accordance with all applicable PCI DSS requirements.	
	6.5.5.b Observe testing processes and interview personnel to verify procedures are in place to ensure live PANs are not used in pre-production environments, except where those environments are in a CDE and protected in accordance with all applicable PCI DSS requirements.	
Customized Approach Objective	**6.5.5.c** Examine pre-production test data to verify live PANs are not used in pre-production environments, except where those environments are in a CDE and protected in accordance with all applicable PCI DSS requirements.	
Live PANs cannot be present in pre-production environments outside the CDE.		

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.

Requirements and Testing Procedures		Guidance
Defined Approach Requirements **6.5.6** Test data and test accounts are removed from system components before the system goes into production.	**Defined Approach Testing Procedures** **6.5.6.a** Examine policies and procedures to verify that processes are defined for removal of test data and test accounts from system components before the system goes into production.	**Purpose** This data may give away information about the functioning of an application or system and is an easy target for unauthorized individuals to exploit to gain access to systems. Possession of such information could facilitate compromise of the system and related account data.
	6.5.6.b Observe testing processes for both off-the-shelf software and in-house applications, and interview personnel to verify test data and test accounts are removed before a system goes into production.	
Customized Approach Objective Test data and test accounts cannot exist in production environments.	**6.5.6.c** Examine data and accounts for recently installed or updated off-the-shelf software and in-house applications to verify there is no test data or test accounts on systems in production.	

©2006 - 2024 PCI Security Standards Council, LLC. All Rights Reserved.